Audit de maturité SSI et audit technique

MEDICA-SERVICES · Rapport d'audit sur pièces

Commanditaire	Direction générale de MEDICA-SERVICES	**Équipe d'audit**	Team, Marc, Matteo et Bernard
Référentiel	SGDN/DCSSI, Maturité SSI, approche méthodologique, 2 novembre 2007	**Dépôt**	10 novembre 2026
Pièces évaluées	P01 à P17, T01 à T10	**Date de référence**	12 octobre 2026 (T06)

La méthode DCSSI de 2007 est utilisée comme référence pédagogique historique. Ses résultats ne valent ni certification ni preuve de conformité réglementaire actuelle. MEDICA-SERVICES, ses pièces et ses montants sont fictifs. Aucun scan ni aucune connexion n'a été réalisé sur une infrastructure réelle.

Synthèse pour la direction

MEDICA-SERVICES héberge et exploite les applications de gestion de douze établissements de soins privés (P01). Son système d'information porte des identifiants de patients et, pour une partie des clients, des données de santé (P05). Une altération non détectée ou une indisponibilité prolongée peut donc atteindre la prise en charge des patients chez des tiers. Ces enjeux conduisent l'autodiagnostic DCSSI à une somme de 10 points, soit un **niveau adéquat de maturité de 4**, sans ajustement proposé. Ce niveau exprime la rigueur souhaitable et non la sécurité déjà atteinte.

Les pièces démontrent une maturité effective de **niveau 1** pour la stratégie, la gestion des risques et la supervision, et de **niveau 2** pour les règles, la conception, la réalisation et l'exploitation. Aucun processus n'atteint le niveau 3, car aucune pratique n'est standardisée sur tout le périmètre. L'écart à la cible est donc de deux à trois niveaux. Plusieurs déclarations de la direction ne sont pas étayées par les pièces techniques. Seuls deux services sur neuf disposent d'un procès-verbal de restauration (T09), et seuls six comptes privilégiés sur dix sont protégés par MFA (T04), alors que la DG et la DSI affirment l'inverse (P17).

Trois risques dominent l'analyse. Le premier est la prise de contrôle d'un compte à privilèges. Le 9 octobre 2026, le compte dormant admin-old, sans MFA, s'est connecté au VPN après trois échecs puis a modifié un groupe d'administrateurs. L'alerte AL-1048 s'est ensuite fermée automatiquement sans ticket (T07, T08). Ces signaux appellent une investigation, sans constituer à eux seuls la preuve d'une intrusion. Le deuxième risque est l'impossibilité de reprendre le service dans les 8 heures contractuelles après un rançongiciel, puisque les postes peuvent joindre le réseau des sauvegardes sans restriction (FW-31, T02) et que les restaurations sont peu éprouvées. Le troisième concerne l'application métier APP01, privée d'un correctif critique depuis 74 jours sans exception validée (T06).

Nous recommandons à la direction de prendre trois décisions. Elle peut d'abord mandater sans attendre l'investigation d'AL-1048, avec des mesures conservatoires sur admin-old et la restriction en régie des règles FW-31 et FW-17. Elle peut ensuite engager 116 000 € sur le plafond de 120 000 €, réparti entre six actions qui couvrent les comptes à privilèges, la supervision, les correctifs, la restauration, la gestion des risques et la révision de la PSSI. Une marge de 4 000 € reste disponible. Il lui revient enfin d'accepter formellement, pour douze mois, les risques résiduels liés au report de la segmentation complète et de la standardisation des projets. Cette trajectoire vise un niveau 2 démontré sur les sept processus à douze mois, première étape cumulative vers la cible.

1 Mission, périmètre et limites (G1)

La direction générale nous a mandatés pour confronter les déclarations, les documents organisationnels et les extraits techniques de MEDICA-SERVICES, afin d'établir le niveau de rigueur souhaitable et la maîtrise réellement démontrée des processus SSI. L'audit porte exclusivement sur les pièces P01 à P17 et T01 à T10. Chaque conclusion distingue le fait documenté, la déclaration, l'interprétation de l'équipe et l'information manquante.

La méthode recommande un périmètre homogène en termes de responsabilité. Nous retenons le service d'hébergement et d'exploitation que MEDICA-SERVICES rend à ses clients, placé sous l'autorité de la direction générale. Ce choix couvre les actifs qui portent les données de patients et laisse hors champ les systèmes propres aux établissements.

L'audit se fonde sur des fragments. Les extraits de configuration ne sont pas accompagnés des journaux de trafic, l'inventaire des dépendances applicatives est partiel et les retards de correctifs sont déclaratifs (T01, T02, T06). Une absence de justificatif est donc traitée comme une incertitude à lever et non comme la preuve qu'une action n'a jamais eu lieu. Trois informations manquantes pèsent particulièrement sur nos conclusions et justifient des demandes de preuves précises.

Table 1. Périmètre retenu

Élément	Contenu retenu	Pièces
Autorité et responsabilités	DG, autorité responsable qui approuve la stratégie. DSI de 14 personnes chargée de l'application. RSSI à mi-temps rattaché à la DSI. DPO externalisé	P02, P09
Bénéficiaires	12 établissements de soins privés, reprise contractuelle sous 8 h des applications critiques	P01
Actifs essentiels	MEDI-PORTAL et sa base de données, identifiants patients et informations de santé, ERP, ticketing	P03, P05, T01
Services supports	35 serveurs ou VM sous Windows et Linux, Active Directory, Microsoft 365, VPN et bastion d'administration, sauvegardes, deux salles dont une de secours chez un prestataire	P03, T01, T09
Interconnexions	Portail HTTPS publié sur Internet, liaisons contractuelles avec les clients, réplication vers le site de secours, SaaS tiers	P03, P07, T01
Limites et exclusions	SI des établissements clients, fonctionnement interne des SaaS tiers et du prestataire de secours, réseaux des agences de Bordeaux et Montpellier non décrits, aucun test actif	P01, T01, T04

Table 2. Informations manquantes et demandes de preuves

Information manquante	Conséquence pour l'audit	Demande de preuve ou question d'entretien
Objectifs de reprise par service (RTO, RPO) et dépendances applicatives (T01, T09)	Impossible de vérifier que l'engagement de 8 h est tenable ni de hiérarchiser les tests de restauration	Analyse d'impact par service, annexes contractuelles de reprise, convention avec le site de secours. Entretien avec le responsable infrastructures
Liste exhaustive des comptes privilégiés, y compris SaaS, et politique d'accès conditionnel (T04)	La couverture MFA de 60 % ne vaut que pour l'export fourni	Export complet de l'annuaire et des consoles SaaS, règles d'accès conditionnel, registre des exceptions approuvées
Suite donnée à l'alerte AL-1048 et intégrité des journaux (T07, T08)	Impossible de qualifier l'événement du 9 octobre	Journaux bruts horodatés et scellés, historique du ticketing, entretien contradictoire avec le titulaire d'admin-old et l'astreinte de la nuit

2 Niveau adéquat de maturité (G2)

Le niveau adéquat traduit les enjeux du périmètre et sert de cible. La méthode note douze questions de 0 à 3, retient le maximum de chaque famille de trois questions, additionne les quatre maxima et convertit la somme selon le barème de 2007. Nos notes reposent sur les pièces citées et la confiance indique la solidité de la preuve, une note fondée sur une simple déclaration restant « probable ».

Table 3. Autodiagnostic DCSSI, notes et justifications (onglet 01)

ID	Question	Note	Pièces	Justification factuelle	Confiance
Q01	Adhérence du SI aux missions	**3**	P01, P03, P04	MEDICA-SERVICES vend l'hébergement et l'exploitation d'applications pour 12 établissements de soins (P01). Sans SI il n'existe plus de prestation et les clients reviennent au papier (P04). Le SI est vital aux missions.	Confirmé
Q02	Impacts internes	**2**	P01, P04	La DG prévoit de fortes pertes contractuelles après une journée d'arrêt et le départ de certains clients si l'arrêt se prolonge (P04). Elle estime pouvoir poursuivre des prestations manuelles, ce qui écarte une conséquence fatale démontrée.	Probable
Q03	Impacts externes	**3**	P04, P05	Les établissements clients basculent sur papier (P04) et une altération non détectée peut provoquer des erreurs d'orientation et de prise en charge de patients (P05). La sécurité de personnes chez des tiers est en jeu. Note fondée sur des déclarations, sans étude d'impact chiffrée.	Probable

ID	Question	Note	Pièces	Justification factuelle	Confiance
Q04	Disponibilité	**2**	P01, P04, P05	Une journée d'arrêt du portail est grave (pertes contractuelles, P04) et un arrêt prolongé affecte fortement la continuité des soins (P05). La DG décrit une activité dégradée et non un arrêt définitif, d'où 2 et non 3. Reprise contractuelle sous 8 h (P01).	Probable
Q05	Intégrité	**3**	P05	Les environnements contiennent des identifiants patients et des informations de santé. Une altération non détectée peut provoquer des erreurs de prise en charge (P05). Pour un hébergeur d'applications de soins, cette perte de confiance peut être fatale à l'activité.	Probable
Q06	Confidentialité	**3**	P05, P07	Identifiants patients et données de santé (P05). La DSI qualifie la divulgation de risque critique et les attaquants visés cherchent la revente de données et l'extorsion (P07).	Probable
Q07	Fréquence des sinistres	**2**	P06	Dix événements SSI enregistrés en 12 mois, soit environ 2,5 par trimestre (P06). Le registre n'étant ni exhaustif ni revu, la fréquence réelle peut être supérieure.	Probable
Q08	Motivation des attaquants	**2**	P07	Menaces ciblées jugées plausibles et potentiellement fortement motivées par la revente de données et l'extorsion (P07). Aucune pièce ne justifie le niveau très important.	Probable
Q09	Moyens des attaquants	**2**	P07	P07 écarte les moyens illimités. Une cybercriminalité d'extorsion dispose plausiblement de moyens importants. Hypothèse d'auditeur sans effet sur le maximum du groupe, déjà fixé à 2 par Q07 et Q08.	Incertain
Q10	Hétérogénéité du SI	**2**	P08, T01	Windows, Linux, hyperviseurs, réseau multi-constructeurs, SaaS et application propriétaire héritée. P08 qualifie l'architecture de fortement hétérogène mais non extrêmement hétérogène.	Confirmé
Q11	Ouverture du SI	**2**	P03, P07, T01, T02	Portail HTTPS publié sur Internet via WEB01 en DMZ (P03, T02) et interconnexions clients encadrées par contrat (P07). Ouverture externe sous contrôle. La note 3 deviendrait défendable si ces contrôles se révélaient inopérants, la somme passerait alors à 11.	Probable
Q12	Variabilité du SI	**2**	P06, P08	Changements applicatifs mensuels et d'infrastructure trimestriels (P08), deux indisponibilités dues à des changements (P06). Le SI change relativement souvent.	Confirmé

Famille	Questions	Max
Conséquences	Q01 à Q03	3
Sensibilité	Q04 à Q06	3
Exposition aux menaces	Q07 à Q09	2
Importance des vulnérabilités	Q10 à Q12	2
Somme		**10**
Niveau calculé	9 à 10	**4**
Ajustement		0
Cible proposée		**4**

La somme des maxima atteint 10, ce qui correspond au niveau 4. Ce résultat est robuste. Il resterait à 4 si l'intégrité et la confidentialité étaient notées 2, puisque la somme vaudrait encore 9. Il ne passerait à 5 que si l'ouverture du SI était jugée hors de contrôle, hypothèse que les contrôles contractuels décrits en P07 ne soutiennent pas.

La méthode autorise l'autorité responsable à ajuster ce niveau d'un cran au plus. Un abaissement à 3 pourrait s'appuyer sur la taille de l'entreprise et sur un RSSI à mi-temps (P02). Nous ne le proposons pas, car les données traitées touchent la santé de patients chez des tiers et un niveau réduit exposerait l'organisme à une gestion de la SSI inférieure à ses enjeux. La contrainte de capacité est mieux traitée par une progression par étapes que par une baisse de l'objectif. Cette proposition reste à valider par la direction générale, seule habilitée à décider de l'ajustement.

3 Maturité effective des sept processus (G3)

L'échelle DCSSI est cumulative. Un niveau n'est attribué que si toutes ses exigences et celles des niveaux inférieurs sont démontrées par les pièces. Le niveau 2 exige ainsi des actions planifiées, menées par une personne compétente en SSI, des pratiques en partie formalisées, des mesures qualitatives et l'information des autorités. Le niveau 3 exige un processus défini, standardisé sur tout l'organisme et soutenu par des ressources. Aucune pièce n'affiche de niveau revendiqué. Les déclarations recueillies portent sur des pratiques et non sur des niveaux, et trois d'entre elles sont contredites (P17).

Table 4. Niveaux revendiqués, démontrés et indéterminés (onglet 02, cible 4)

Processus	Revendiqué	Démontré	Niveau supérieur	Preuves	Écart
Définir la stratégie SSI	Non déclaré	**1**	N2 indéterminé (mesures qualitatives et traces de compte rendu absentes)	P09, P02, P17	3
Gérer les risques SSI	Non déclaré	**1**	N2 non atteint (pas de planification ni de méthode)	P10, P06	3
Gérer les règles SSI	Non déclaré	**2**	N3 non atteint (pas de processus standardisé)	P11, P17, T06	2
Superviser la SSI	Non déclaré	**1**	N2 non atteint (contrôles non planifiés, pas de reporting)	P12, P06, T08	3
Concevoir les mesures SSI	Non déclaré	**2**	N3 non atteint (démarche non uniformisée)	P13, T02	2
Réaliser les mesures SSI	Non déclaré	**2**	N3 non atteint (modalités non normalisées)	P14, T02	2
Exploiter les mesures SSI	Non déclaré	**2**	N3 non atteint (pas de processus commun standardisé)	P15, P17, T03, T04, T06, T09	2

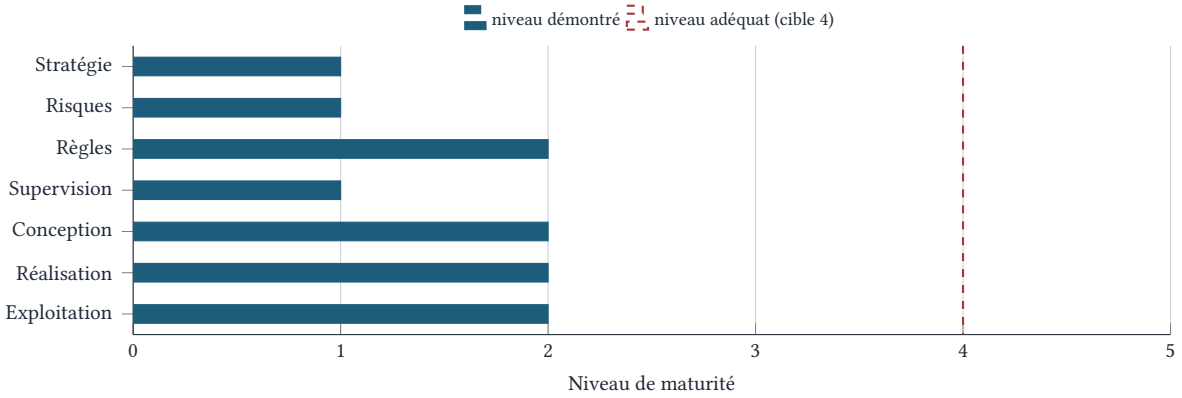


Figure 1. Niveaux démontrés et niveau adéquat. Les barres reprennent la colonne C de l'onglet 02.

Trois processus restent au niveau 1. La gestion des risques repose sur des recensements ponctuels en projet, sans calendrier, méthode réutilisable ni registre approuvé (P10). La supervision dispose d'outils et d'alertes, mais aucun contrôle n'est planifié et aucun reporting régulier n'existe (P12), ce que confirme la fermeture automatique d'AL-1048 (T08). La stratégie présente plusieurs éléments du niveau 2, avec une note d'orientation approuvée, des priorités annuelles et un compte rendu semestriel (P09). Comme ce compte rendu reste oral et qu'aucune mesure qualitative n'est produite, nous classons le niveau 2 comme indéterminé faute de preuve plutôt que comme non atteint.

Les quatre autres processus atteignent le niveau 2. Pour les règles, la PSSI approuvée, l'application planifiée et les contrôles qualitatifs consignés suffisent (P11), même si l'absence de procès-verbaux de revue fragilise ce niveau (P17). La conception et la réalisation reposent sur des fiches types, des revues planifiées et des comptes rendus de validation (P13, P14). Pour la réalisation, la planification se déduit de la préparation et du suivi réguliers et doit être confirmée sur pièces. L'exploitation remplit les exigences du niveau 2 pour les sauvegardes (P15), mais les constats techniques montrent que ce niveau reste fragile. Aucune anomalie technique isolée ne suffit pourtant à retirer un niveau entier, et nous l'utilisons pour orienter la progression plutôt que pour noter.

Le tableau suivant détaille, pour chaque processus, les preuves retenues, les exigences cumulatives qui ne sont pas établies et l'étape de progression proposée avec la preuve qui permettra de la constater. Il reprend les colonnes D, E et G de l'onglet 02.

Table 5. Exigences non établies et progression par processus

Processus	Preuves	Exigences non établies et réserves	Étape suivante et preuve de réussite
Définir la stratégie SSI	P09, P02, P17	Niveau 1 étayé par la note d'orientation 2024 approuvée par la DG, des priorités annuelles et un référent (P09). Niveau 2 indéterminé car aucune mesure qualitative n'est produite et le compte rendu semestriel reste oral, sans trace. Niveau 3 non atteint, faute de processus commun documenté (P09). Revue annuelle de la PSSI sans PV depuis deux ans (P17).	Tableau de bord qualitatif semestriel et comptes rendus écrits validés par la DG. Preuve : deux PV de revue datés.

Processus	Preuves	Exigences non établies et réserves	Étape suivante et preuve de réussite
Gérer les risques SSI	P10, P06	Risques recensés ponctuellement lors de projets récents, avec des mesures décidées (P10). Niveau 2 non atteint : ni calendrier de revue, ni méthode réutilisable, ni registre consolidé approuvé. L'analyse du prestataire de 2025 reste isolée.	Méthode simple, registre consolidé et revue trimestrielle (A01). Preuve : registre approuvé par la DG et PV de revue.
Gérer les règles SSI	P11, P17, T06	Niveau 2 étayé par une PSSI approuvée, des règles écrites, une application planifiée, des contrôles qualitatifs consignés et l'information des managers (P11). Niveau 3 non atteint, les textes ne forment pas un processus commun. Fragilités : revue annuelle sans PV (P17) et aucune cible de délai de correctifs (T06).	PSSI révisée avec délais de correctifs par criticité, diffusée à tout le périmètre (A03). Preuve : PSSI v2 approuvée, PV de revue, taux de sensibilisation.
Superviser la SSI	P12, P06, T08	Outil de journalisation et alertes actifs, interventions à la demande (P12), d'où le niveau 1. Niveau 2 non atteint : aucune campagne de contrôle planifiée, aucun reporting régulier ni procédure commune (P12). AL-1048 fermée automatiquement sans ticket (T08).	Plan de contrôle annuel, procédure de traitement des alertes et reporting mensuel (A02). Preuve : échantillon de tickets d'alerte qualifiés et rapports mensuels.
Concevoir les mesures SSI	P13, T02	Besoins identifiés sur certains projets, fiche type, responsable technique, revues planifiées pour les projets majeurs avec compte rendu (P13). Niveau 3 non atteint, la démarche n'est pas globale. La règle FW-17 déclarée provisoire et toujours active (T02) montre que les changements mineurs échappent à la démarche.	Fiche de besoins SSI obligatoire pour tout projet ou changement significatif (préparée en régie, A04 différée). Preuve : fiches sur un échantillon de projets.
Réaliser les mesures SSI	P14, T02	Techniciens compétents, comptes rendus d'installation et de validation, suivi régulier avec information de la DSI (P14). La planification est déduite de la préparation et du suivi réguliers, elle reste à confirmer sur pièces. Niveau 3 non atteint. Règles FW-17 et FW-31 sans justification ni validation (T02).	Modèle commun de recette sécurité et revue des règles déployées. Preuve : PV de recette standardisés sur trois déploiements.
Exploiter les mesures SSI	P15, P17, T03, T04, T06, T09	Sauvegardes planifiées, comptes rendus hebdomadaires, astreinte, procédure de restauration connue et bilan qualitatif mensuel à la DSI (P15). Niveau 3 non atteint. Fragilités : 2 PV de test sur 9 services (T09), MFA sur 6 comptes privilégiés sur 10 (T04), correctifs en retard sans exception (T06), déclarations contredites (P17).	Standardiser restauration, correctifs et revue des comptes (A05, A08, A09). Preuve : PV de restauration avec RTO et RPO mesurés, export MFA, SLA de correctifs.

4 Audit technique sur pièces (T1 à T4)

4.1 Architecture, flux et segmentation (T1)

Le schéma T01 décrit un cloisonnement en zones dont la logique est saine dans son principe. Le portail est publié en DMZ derrière FW01, l'application et la base sont isolées dans le VLAN 20, et l'administration passe par un VPN et un bastion. La surface exposée à Internet observée se limite à WEB01, qui répond sur 80 et 443 avec SSH filtré (T02), et au point d'entrée VPN. Ces ouvertures sont attendues pour un portail public et ne constituent pas en elles-mêmes une faille exploitée. Quatre règles s'écartent toutefois du principe de moindre privilège et appellent des contrôles complémentaires.

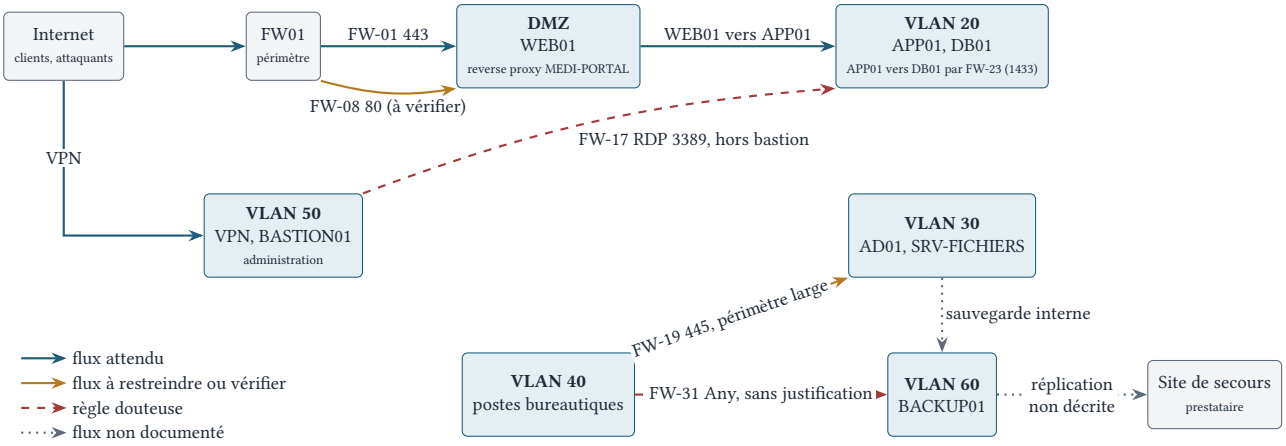


Figure 2. Zones de confiance et flux extraits de T01 et T02. Les règles sont tracées telles qu'extraites, sans journaux de trafic.

4.2 Identités, privilèges et MFA (T2)

L'export T03 recense dix comptes privilégiés, dont six sont enrôlés MFA (T04). La couverture est donc de $6/10 = 60\,\%$ sur le périmètre fourni, ce qui concorde avec P03 et contredit la DSI, qui affirme que tous les comptes privilégiés en

Table 6. Règles douteuses et contrôles complémentaires

Règle	Constat	Lecture prudente	Contrôle complémentaire
FW-08	HTTP 80 ouvert sur WEB01	Redirection déclarée par la DSI, non vérifiée	Requête de test et en-tête HSTS
FW-17	RDP direct du VPN vers tout le VLAN 20, déclaré provisoire	Contourne le bastion, donc la traçabilité des sessions	Date d'expiration, journaux de connexion, passage forcé par BASTION01
FW-19	SMB 445 de tous les postes vers le VLAN 30	Périmètre large au regard du besoin métier	Liste des partages et des groupes, restriction par groupe
FW-31	Any des postes vers les sauvegardes, règle héritée	Aucune justification. Un poste compromis pourrait atteindre BACKUP01	Journaux sur 30 jours, suppression ou restriction, test de segmentation

disposent (P17). Si le compte de service svc-backup est réellement non interactif, la couverture des comptes interactifs atteint $6/9 \approx 66{,}7\,\%$, et elle passerait à $6/8 = 75\,\%$ après la désactivation d'admin-old. Le résultat ne couvre pas les administrateurs des SaaS tiers. Quatre comptes appellent une action immédiate. Admin-old, administrateur de domaine dont la dernière activité documentée date du 14 février 2025, doit être désactivé à titre conservatoire, d'autant qu'il apparaît dans les journaux du 9 octobre 2026. Admin-presta et admin-db doivent être enrôlés MFA ou faire l'objet d'une exception approuvée. Svc-backup doit recevoir une interdiction technique d'ouverture de session interactive. La clôture sera vérifiée par un export exhaustif à 100 % ou accompagné d'exceptions signées, et par la preuve de la restriction de svc-backup.

Table 7. Comptes privilégiés à revoir (T03, T04)

Compte	Rôle	Dernière activité	Mesure immédiate	Preuve de clôture
admin-old	Domain Admin, sans MFA	2025-02-14 selon T03, connexion le 09/10/2026 selon T07	Désactivation conservatoire et réinitialisation, revue de Server-Admins	Compte désactivé, liste des membres avant et après
admin-presta	Admin VPN prestataire, sans MFA	2026-09-20	Enrôlement MFA ou exception signée, contrôle de la clause contractuelle	Export MFA, exception datée et approuvée
admin-db	Admin base de données, sans MFA	2026-10-04	Enrôlement MFA	Export MFA
svc-backup	Compte technique à droits élevés, sans MFA	2026-10-11	Refus d'ouverture de session interactive, secret en coffre, rotation	Stratégie appliquée, journal sans session interactive

4.3 Vulnérabilités et correctifs (T3)

Le score CVSS décrit la gravité technique d'une vulnérabilité dans l'absolu. Le risque métier dépend en plus de l'exposition de l'actif, de sa criticité et des mesures compensatoires. C'est pourquoi le correctif manquant d'APP01 passe en tête malgré l'absence d'exposition directe, tandis que TLS 1.0 sur WEB01, pourtant exposé, reste de priorité modérée.

Table 8. Classement des constats de vulnérabilité au 12 octobre 2026

Actif	CVSS	Exposition	Criticité	Retard	Priorité	Éléments de validation demandés
APP01	9,8	Joignable depuis la DMZ et par FW-17	Critique	74 j	1, élevée	CVE et version, avis éditeur, historique de déploiement, exception
SRV-FICHIERS	6,5	Tout le VLAN 40 par FW-19	Moyenne	43 j	2, élevée	Validation manuelle de la signature SMB, liste des partages
WEB01	5,3	Internet	Haute	12 j	3, modérée	Test TLS manuel, vérification de la redirection
AD01	·	Interne	Critique	0 j	Contrôle	Inventaire authentifié récent, l'actuel datant du 25/09/2026

Aucune exception n'est documentée et la PSSI ne fixe aucun délai par criticité (T06, P11). Les retards restent déclaratifs

tant que les historiques de déploiement ne sont pas fournis.

4.4 Détection, journaux et sauvegardes (T4)

La chronologie suivante reprend les seuls éléments de T07 et T08, en heure UTC. Elle décrit des faits observés sans les interpréter.

Table 9. Chronologie neutre du 9 octobre 2026

Heure UTC	Source	Événement observé	Écart
00:13:01 à 07	VPN	Trois échecs d'authentification d'admin-old depuis 198.51.100.44	
00:13:12	VPN	Authentification réussie du même compte, même adresse	11 s après le premier échec
00:18:32	AD	Ajout par admin-old dans le groupe Server-Admins	5 min 20 s après le succès
00:22:15	SIEM	Alerte AL-1048, sévérité HIGH, ouverte	3 min 43 s plus tard
10/10 00:22	SIEM	Fermeture automatique, aucun ticket, aucune investigation tracée	24 h

Ces signaux sont compatibles avec un usage illégitime du compte, mais aussi avec une intervention nocturne d'administration non documentée. La compromission n'est pas prouvée, faute de vérification de l'intégrité des journaux, de trace du second facteur et d'échange avec le titulaire. Une incohérence renforce la nécessité d'enquêter. L'export T03, dont les autres dates vont jusqu'au 11 octobre, affiche pour admin-old une dernière activité au 14 février 2025, ce qui ne reflète pas la connexion du 9 octobre. Nous recommandons donc des mesures conservatoires immédiates, avec la désactivation du compte, la revue des membres de Server-Admins et la préservation des journaux, puis une investigation formelle.

Table 10. Sauvegardes et tests de restauration documentés (T09)

Service	Sauvegarde	Dernier test documenté	Lecture
MEDI-PORTAL	Planifiée	15/09/2026	PV sans durée mesurée
Ticketing	Planifiée	16/09/2026	PV sans durée mesurée
ERP, Active Directory, fichiers, base MEDI, supervision	Planifiée	Aucun PV fourni	Test non démontré, pas exclu
Messagerie M365	Sauvegarde tierce alléguée	Aucun PV fourni	Contrat et périmètre à obtenir
VPN et bastion	Configuration exportée	Aucun PV fourni	Restauration de configuration à tester

Pour les sauvegardes, les neuf services du périmètre sont sauvegardés ou déclarés tels, mais seuls MEDI-PORTAL et le ticketing disposent d'un procès-verbal de test, daté des 15 et 16 septembre 2026 (T09). La couverture documentée est donc de $2/9 \approx 22\,\%$, loin de la déclaration selon laquelle toutes les restaurations seraient testées chaque trimestre (P17). L'absence de procès-verbal ne prouve pas l'absence de test, et les deux procès-verbaux existants ne prouvent pas le respect du délai de 8 heures, car aucune durée ni aucun RPO n'y figurent. Nous proposons des critères mesurables, à faire valider par la direction. Chaque service devrait disposer d'au moins un procès-verbal par an et les quatre services critiques, MEDI-PORTAL, sa base, l'AD et l'ERP, d'un procès-verbal par trimestre mesurant une durée de restauration inférieure à 8 heures. Toute alerte de sévérité HIGH devrait par ailleurs donner lieu à un ticket qualifié avant sa clôture.

5 Corrélation gouvernance et technique (T5)

La matrice relie chaque constat technique à sa preuve, au scénario de risque, au processus DCSSI concerné et au niveau effectivement démontré. Le niveau indiqué résulte de l'examen cumulatif de la section 3 et non du seul constat. Le terme « fragile » signale un niveau acquis sur pièces mais contredit en partie par la technique. Les onze constats sont d'abord présentés avec leur qualification, puis les six plus structurants sont corrélés.

Table 11. Registre des constats techniques (onglet 03, colonnes A à D et G)

ID	Pièces	Observation	Qualification et réserve	Priorité justifiée
C01	T03/T04	10 comptes privilégiés recensés, 6 enrôlés MFA (60 %). Sans MFA : svc-backup, admin-old (Domain Admin, dernière activité documentée 2025-02-14), admin-presta (VPN prestataire) et admin-db.	Fait documenté sur le périmètre de l'export (annuaire et administrateurs VPN). Exhaustivité SaaS non garantie, accès conditionnel et exceptions non fournis. Contredit la déclaration de la DSI (P17).	Élevée : privilèges étendus, accès VPN exposé, signaux T07 sur admin-old.
C02	T02/T01	La règle FW-31 autorise tout service du VLAN 40 (postes) vers le VLAN 60 (BACKUP01). Règle héritée sans justification.	Configuration extraite sans journaux de trafic. Usage réel inconnu. Aucune exploitation constatée.	Élevée : les sauvegardes sont le dernier recours de reprise et l'hameçonnage est fréquent (P06).
C03	T05/T06	APP01 (criticité métier critique) sans correctif critique éditeur (CVSS communiqué 9,8), retard de 74 jours au 12/10/2026, exception non documentée.	Non exposé directement à Internet et non exploité pendant l'audit. CVE, version et historique de déploiement absents. Retard déclaratif.	Élevée : actif critique joignable depuis la DMZ, aucune exception validée. Le score seul ne fixe pas la priorité.
C04	T07/T08	Le 09/10/2026, trois échecs puis un succès VPN pour admin-old depuis 198.51.100.44 (00:13), ajout au groupe Server-Admins (00:18), alerte AL-1048 de sévérité HIGH (00:22) fermée automatiquement après 24 h sans ticket.	Signaux compatibles avec un événement à investiguer, pas une compromission prouvée. Intégrité des journaux, trace MFA et contact du titulaire non fournis. Incohérence avec la dernière activité T03 (2025-02-14).	Très élevée : privilège Domain Admin, compte dormant sans MFA, alerte non examinée.
C05	T09	9 services dans le périmètre, 2 PV de test (MEDI-PORTAL le 15/09, ticketing le 16/09/2026), 7 sans PV. RPO non fourni. Sauvegarde M365 alléguée chez un tiers.	L'absence de PV ne prouve pas l'absence de test. Les deux PV ne prouvent pas le RTO de 8 h (P01). Déclaration de la DG contredite (P17).	Élevée : engagement contractuel et continuité des soins (P01, P05).
C06	T02/T01	FW-17 autorise RDP (3389/TCP) depuis VPN-ADMIN vers tout le VLAN 20, sans passer par BASTION01. Règle déclarée provisoire.	Durée, utilisateurs et journaux non fournis. Le contournement du bastion est déduit du schéma T01.	Élevée : accès d'administration direct vers les serveurs critiques.
C07	T02/T05/T06	FW-19 ouvre SMB (445/TCP) de tout le VLAN 40 vers le VLAN 30. Signature SMB non obligatoire sur SRV-FICHIERS (CVSS 6,5). Correctifs en retard de 43 jours.	Constat de scanner non validé manuellement. Périmètre « large » sans liste des partages.	Moyenne à élevée : exposition interne étendue et hameçonnage fréquent.
C08	T02/T05	WEB01 répond sur 80/tcp et 443/tcp, 22/tcp filtré. Le scanner signale TLS 1.0 (CVSS 5,3). La redirection HTTP vers HTTPS est déclarée, non vérifiée.	Validation manuelle absente. Un port ouvert ne prouve pas une faille exploitée.	Modérée : exposé à Internet mais impact limité si la redirection est effective.
C09	T06/P11/T05	La PSSI ne fixe aucun délai de correctifs par criticité. Retards de 12 j (WEB01), 43 j (SRV-FICHIERS) et 74 j (APP01) sans exception validée. AD01 à jour selon l'agent (inventaire du 25/09/2026).	Retards déclaratifs, historiques de déploiement absents. Inventaire AD01 ancien de 17 jours à la date de contrôle.	Élevée : cause commune de C03, C07 et C08.
C10	P06/P12/T08	Registre de 10 événements non exhaustif et non revu en comité (P06). Alertes parfois conservées dans les tickets (P12), AL-1048 sans ticket (T08).	Pièces de gouvernance déclaratives, cohérentes avec T08.	Élevée : conditionne la détection.
C11	T03/T09	svc-backup, compte technique à droits élevés sans MFA, déclaré non interactif par la DSI sans preuve de restriction.	Déclaration non étayée. Lien avec BACKUP01 probable mais non documenté.	Élevée : touche la capacité de reprise.

Table 12. Matrice constat, preuve, risque, processus, action et vérification

Constat	Preuve	Risque	Processus	Niveau	Action	Pilote	Vérification
C04 AL-1048 fermée sans ticket	T07/T08	R01	Superviser la SSI	Supervision 1	A02	RSSI	Ticket d'incident qualifié, rapport d'investigation, membres de Server-Admins avant et après, paramétrage SIEM modifié.
C01 MFA sur 6 comptes privilégiés sur 10	T03/T04	R01	Exploiter les mesures SSI	Exploitation 2, fragile	A08	DSI (IAM)	Export MFA exhaustif à 100 % ou exceptions approuvées, preuve de restriction de svc-backup, revue des groupes à privilèges.
C05 PV de restauration pour 2 services sur 9	T09	R02	Exploiter les mesures SSI	Exploitation 2, fragile	A05	Resp. infra-structures	PV de restauration datés avec durée mesurée et RPO constaté pour chaque service.

Constat	Preuve	Risque	Processus	Niveau	Action	Pilote	Vérification
C03 Correctif critique APP01 en retard de 74 jours	T05/T06	R03	Exploiter les mesures SSI	Exploitation 2, fragile	A09	Resp. infra-structures	Scan authentifié après correctif, ticket de changement, version installée.
C02 FW-31 Any des postes vers les sauvegardes	T02/T01	R02	Concevoir / Réaliser les mesures SSI	Réalisation 2, fragile	Régie (A10 différée)	DSI réseau	Règle supprimée ou justifiée et approuvée, journaux de trafic sur 30 jours, test de segmentation.
C09 Aucun délai de correctifs par criticité	T06/P11/ T05	R03	Gérer les règles SSI	Règles 2	A03	RSSI	SLA approuvés, tableau mensuel de conformité, exceptions signées.

Ces corrélations montrent que les faiblesses techniques prolongent les lacunes de pilotage. L'alerte fermée sans ticket découle directement d'une supervision restée au niveau 1. Les retards de correctifs et l'absence d'exception traduisent des règles qui ne fixent aucun délai. Les procès-verbaux manquants révèlent une exploitation dont les résultats ne sont pas mesurés. Traiter ces faiblesses une à une sans faire progresser les processus reviendrait à corriger des symptômes.

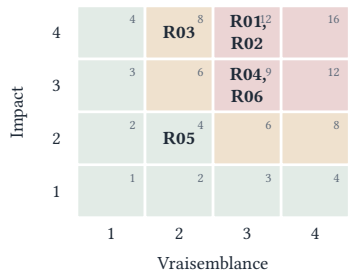
6 Scénarios de risque, arbitrage et feuille de route (G4)

6.1 Registre des risques

Les six scénarios suivants reformulent les constats en enjeux métier. La cotation de 1 à 4 suit la grille simplifiée de la notice et le score est le produit de l'impact par la vraisemblance. Les hypothèses de cotation sont explicites. L'impact tient compte des données de santé et du délai de reprise contractuel, et la vraisemblance de l'exposition, de la menace décrite en P07 et des mesures existantes.

Table 13. Registre des risques (onglet 04, I impact, V vraisemblance)

ID	Événement redouté	Actif	Vulnérabilité ou faiblesse	I	V	I×V	Décision
R01	Prise de contrôle d'un compte à privilèges menant à une modification non autorisée de l'infrastructure (AD, serveurs)	AD01, BASTION01 et VPN, groupe Server-Admins	4 comptes privilégiés sur 10 sans MFA dont admin-old dormant et admin-presta, RDP direct FW-17, AL-1048 non traitée	4	3	**12**	Réduire (A08, A02) et mesures conservatoires immédiates. Décision DG sur proposition du RSSI.
R02	Indisponibilité de MEDI-PORTAL au-delà du RTO de 8 h faute de restauration fiable (rançongiciel ou panne)	MEDI-PORTAL, base de données MEDI, BACKUP01	2 tests documentés sur 9 services, RPO inconnu, FW-31 Any des postes vers les sauvegardes, svc-backup non restreint	4	3	**12**	Réduire (A05, A08) et restriction de FW-31 en régie. Décision DG.
R03	Altération ou divulgation de données patients via l'application métier non corrigée	APP01, DB01	Correctif critique manquant depuis 74 jours, aucun SLA, flux WEB01 vers APP01, RDP FW-17	4	2	**8**	Réduire (A09). Exception signée et mesures compensatoires si le correctif est reporté.
R04	Divulgation de données de santé depuis les partages de fichiers après compromission d'un poste	SRV-FICHIERS, AD01	SMB ouvert à tout le VLAN 40 (FW-19), signature non obligatoire, retard de correctifs de 43 jours	3	3	**9**	Réduire partiellement (A09, A03). Segmentation complète A10 différée, risque résiduel accepté par la DG pour 12 mois.
R05	Interception ou dégradation des sessions du portail public	WEB01, MEDI-PORTAL	TLS 1.0 signalé, port 80 ouvert, redirection non vérifiée	2	2	**4**	Réduire à faible coût dans A09, sinon accepter temporairement.
R06	Indisponibilité ou altération de service causée par un changement mal maîtrisé	MEDI-PORTAL, infrastructure	Conception et réalisation non standardisées (P13, P14), règle provisoire non retirée (FW-17)	3	3	**9**	Accepter temporairement (A04 différée en année 2) avec revue de changement renforcée en régie. Risque résiduel porté par la DO.



R01 et R02 obtiennent le score le plus élevé, 12, car ils combinent un impact critique et des faiblesses observées sur des chemins d'attaque plausibles. R03 obtient 8. Son impact est maximal mais l'absence d'exposition directe d'APP01 réduit sa vraisemblance. R04 et R06 partagent un score de 9 sans appeler le même traitement. Le premier relève de la confidentialité et se réduit par des réglages techniques, tandis que le second dépend de la standardisation des projets, différée en année 2. Un score égal ne vaut donc pas décision identique.

6.2 Arbitrage sous plafond de 120 000 €

Les montants viennent de P16 et des options T10. Le lot de restauration de 22 000 € n'est compté qu'une fois, car T10 précise qu'il s'agit de la même prestation que dans P16. L'outillage quantitatif (A06) et la détection outillée (A11) sont des alternatives de 35 000 € chacune, sans équivalence garantie. Nous les différons toutes deux. La mesure quantitative est une exigence du niveau 4 et serait prématurée pour des processus aux niveaux 1 et 2. Le besoin immédiat de traitement des alertes est couvert par la procédure de supervision (A02).

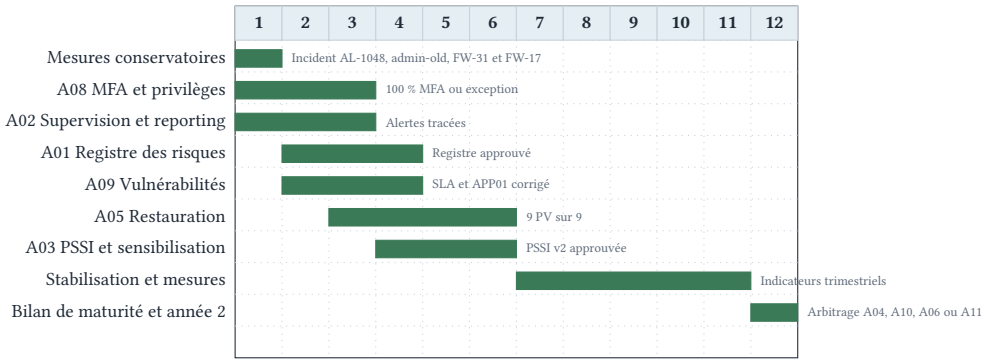
Table 14. Plan d'action et arbitrage budgétaire (onglet 05)

ID	Mesure	Coût	Choix	Pilote	Échéance et livrable	Justification
A01	Registre et méthode des risques	18 000 €	**Retenu**	RSSI	T+4 mois : méthode, registre consolidé approuvé par la DG, revue trimestrielle	Gérer les risques au niveau 1 (P10). Base de tous les arbitrages R01 à R06.
A02	Supervision et reporting	16 000 €	**Retenu**	RSSI et exploitation	T+3 mois : procédure de traitement des alertes, plan de contrôle, reporting mensuel	Superviser au niveau 1 (P12). AL-1048 fermée sans ticket (C04, C10). R01.
A03	PSSI et sensibilisation	14 000 €	**Retenu**	RSSI et RH	T+6 mois : PSSI révisée avec SLA de correctifs, PV de revue, campagne anti-hameçonnage	5 hameçonnages sur 10 événements (P06), revue PSSI sans PV (P17), aucun SLA (C09). R04.
A04	Standardisation conception et réalisation	24 000 €	Différé	DSI	Différée en année 2	Conception et réalisation déjà au niveau 2. Fiche SSI obligatoire préparée en régie. Risque résiduel R06.
A05	Restauration et incidents	22 000 €	**Retenu**	Resp. infrastructures	T+6 mois : PV de restauration pour 9 services sur 9, RTO et RPO mesurés, procédure d'incident	2 tests sur 9 (T09), RTO de 8 h (P01). R02. Même lot que T10 restauration, compté une seule fois.
A06	Outillage quantitatif	35 000 €	Différé	RSSI	Différée en année 2	La mesure quantitative relève du niveau 4, prématurée avec des processus à 1 ou 2. Alternative à A11, non cumulée.
A07	Conduite du changement	14 000 €	Différé	DG et RH	Différée en année 2	Utile mais moins urgente que R01 et R02. Accompagnement porté en interne par le RSSI.
A08	MFA et privilèges	28 000 €	**Retenu**	DSI (IAM)	T+3 mois : 100 % des comptes privilégiés sous MFA ou exception approuvée, revue des privilèges, svc-backup restreint	C01, C04, C11. R01 et R02. Déclaration P17 contredite.
A09	Vulnérabilités et correctifs	18 000 €	**Retenu**	Resp. infrastructures	T+4 mois : inventaire authentifié, SLA par criticité, APP01 corrigé, TLS 1.0 retiré, signature SMB	C03, C07, C08, C09. R03, R04 et R05.
A10	Segmentation réseau	30 000 €	Différé	DSI réseau	Différée en année 2, FW-31 et FW-17 restreintes en régie sous un mois	Plafond atteint. Risque résiduel R04 et part de R02 acceptés par la DG pour 12 mois.
A11	Détection et workflow SIEM	35 000 €	Différé	RSSI	Différée en année 2	Recoupe A02 pour le workflow d'alerte. Outil à choisir après stabilisation au niveau 2. Alternative à A06.
	Engagement total	**116 000 €**		Marge 4 000 € sur un plafond de 120 000 €, statut « budget respecté »		

Le choix privilégie les risques R01 et R02 et les processus les plus faibles, conformément au principe de la méthode qui consiste à faire progresser d'abord les processus de plus bas niveau. La segmentation complète (A10) est la principale mesure différée. Ses effets les plus urgents sont obtenus sans coût externe par la restriction en régie de FW-31 et FW-17, hypothèse à confirmer avec la DSI. Les risques résiduels R04, R06 et la part de R02 liée au cloisonnement restent portés pendant douze mois et doivent être acceptés par écrit par la direction générale. La marge de 4 000 € couvre de petits imprévus et ne finance aucune mesure supplémentaire.

6.3 Feuille de route SSI sur douze mois

Cette feuille de route concerne MEDICA-SERVICES et ne doit pas être confondue avec le calendrier de production de notre projet présenté en section 7. Elle suppose une décision du CODIR à la mi-novembre 2026, le premier mois correspondant à décembre 2026.



Processus	Actuel	M6	M12	Cible
Stratégie	1	2	2	4
Risques	1	2	2	4
Règles	2	2	3	4
Supervision	1	2	2	4
Conception	2	2	2	4
Réalisation	2	2	2	4
Exploitation	2	2	3	4

La progression est cumulative. Les six premiers mois portent la stratégie, les risques et la supervision au niveau 2, ce qui aligne les sept processus sur ce niveau. Le second semestre stabilise ces pratiques et prépare le niveau 3 pour les règles et l'exploitation, qui disposent déjà de textes et de comptes rendus réguliers. Le niveau 4 reste l'objectif à moyen terme et suppose une seconde enveloppe. Chaque palier sera validé par les preuves de clôture indiquées dans la grille et non par déclaration.

7 Organisation du travail de l'équipe

Le projet a été mené par Team, Marc, Matteo et Bernard entre le 20 octobre et le 10 novembre 2026. Les barres du diagramme représentent des fenêtres de réalisation compatibles avec les autres enseignements, et non une activité quotidienne à temps plein. La répartition suit les deux parties du barème. Team coordonne, cadre le périmètre et assemble le rapport. Marc porte l'autodiagnostic et les sept processus. Matteo traite l'architecture, les identités et la corrélation, puis prépare la présentation CODIR. Bernard analyse les vulnérabilités, les journaux et les sauvegardes et tient la grille Excel, qu'il remplit au fil des analyses. Un atelier commun le 29 octobre confronte les premières notes, et les relectures sont croisées entre gouvernance et technique.

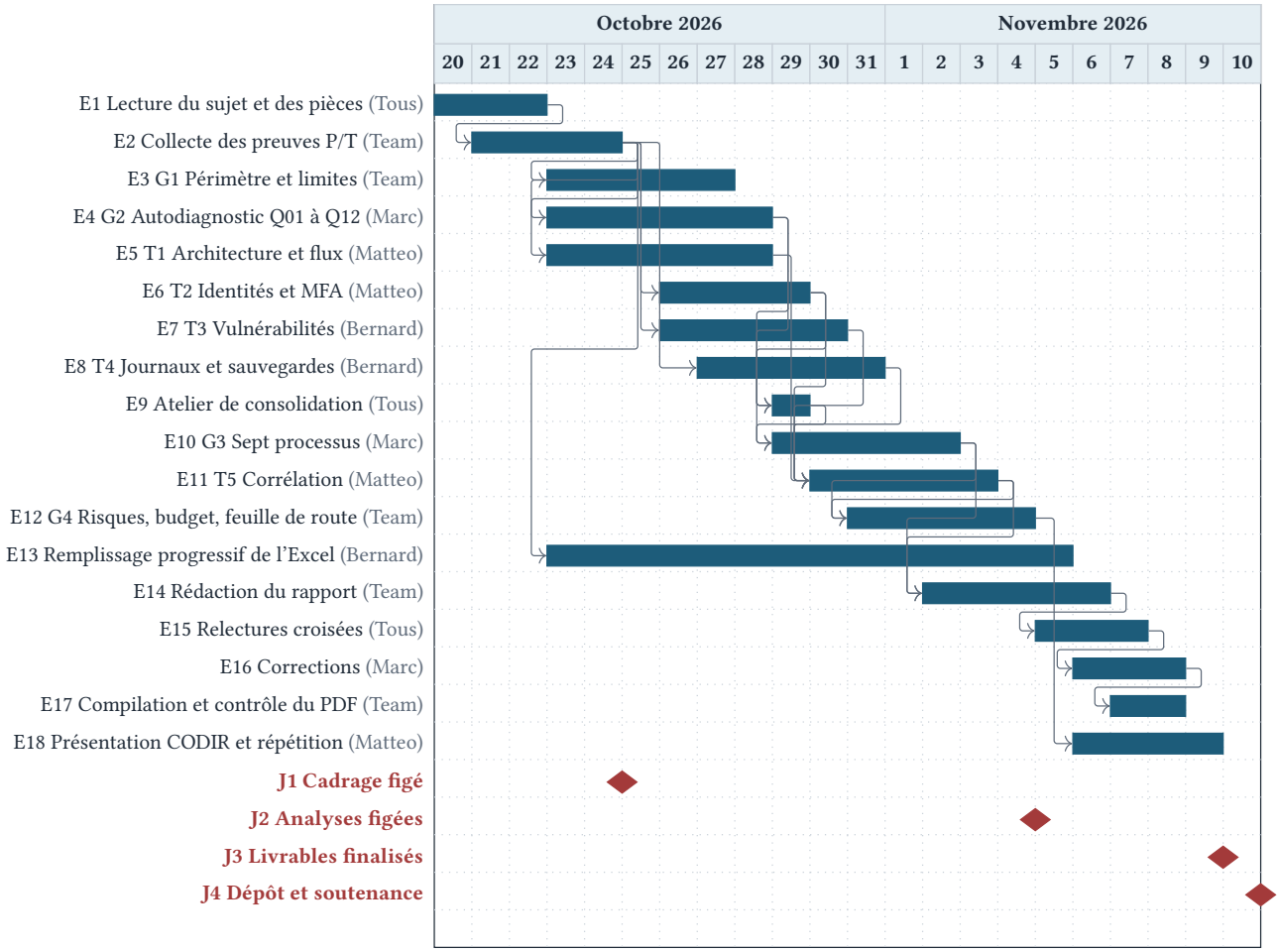


Figure 3. Diagramme de Gantt du projet, responsables entre parenthèses, dépendances fléchées et jalons J1 à J4.

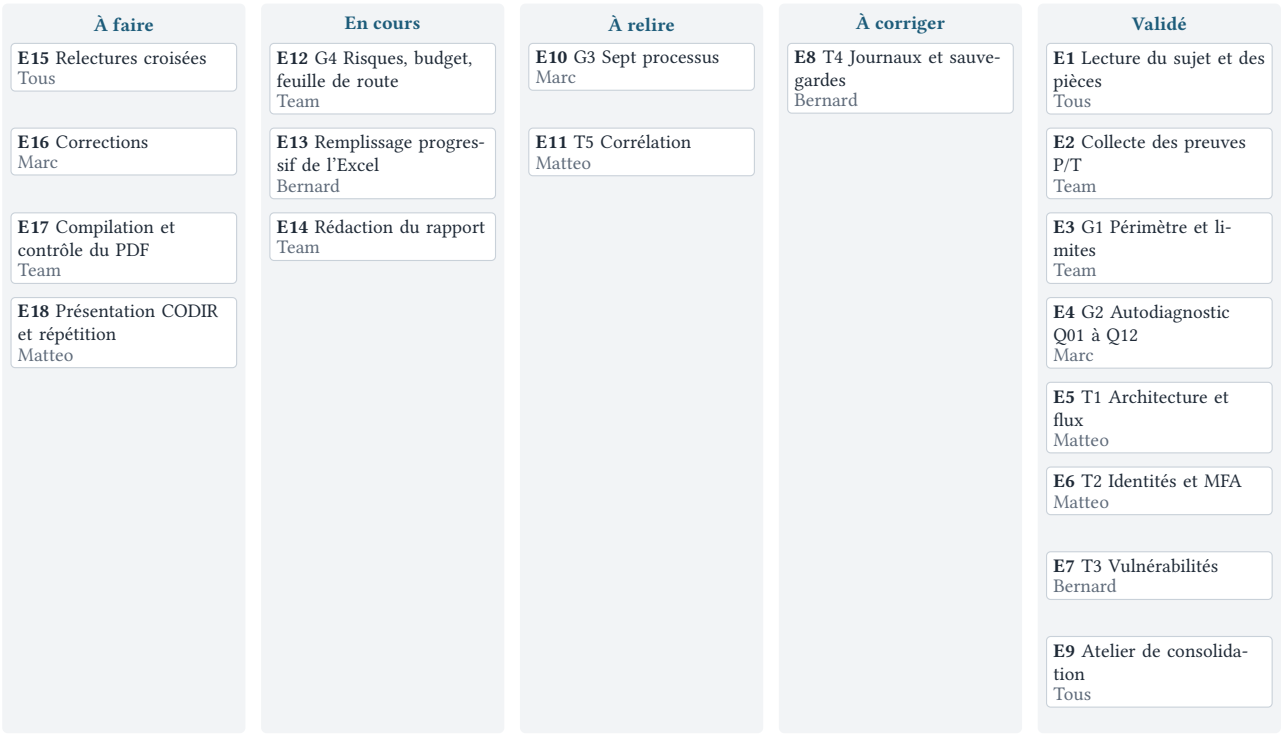


Figure 4. Kanban projeté au 6 novembre 2026 à partir du planning cible. Les identifiants E1 à E18 sont ceux du Gantt.

Les deux représentations décrivent le planning cible et non un avancement constaté. Le Kanban place chaque tâche dans la colonne prévue au 6 novembre, veille des relectures croisées, et l'état réellement atteint par chaque tâche reste

à renseigner par l'équipe. Aucune tâche n'est présentée comme accomplie sur la seule base du calendrier. Ce calendrier de production est distinct de la feuille de route SSI de MEDICA-SERVICES présentée en section 6.

8 Conclusion et suites à donner

MEDICA-SERVICES dispose de fondations réelles, avec une stratégie approuvée, une PSSI, des sauvegardes planifiées et des équipes compétentes. Ses pratiques restent toutefois dépendantes des personnes et ne produisent pas les preuves qui permettraient à la direction de vérifier ses propres affirmations. L'écart de deux à trois niveaux avec la cible 4 ne se comblera pas en une année. Le plan proposé traite d'abord les risques les plus graves et ramène les processus les plus faibles au niveau 2, dans le respect du plafond.

Quatre demandes de preuves conditionnent la confirmation de nos conclusions. Il s'agit du dossier d'investigation d'AL-1048 avec les journaux bruts, de l'export exhaustif des comptes privilégiés y compris SaaS, des procès-verbaux de restauration des sept services sans preuve de test, et des historiques de déploiement des correctifs avec la version installée sur APP01. Leur production pourra faire évoluer certains niveaux, notamment le niveau 2 de la stratégie aujourd'hui indéterminé, sans remettre en cause le niveau adéquat.